

CYROPAY LTD

Vulnerability and Patch Management Policy

Document Information

Document ID	POL-010
Document Classification	Internal
Version	1.0
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Effective Date	May 2026
Review Date	May 2027
Status	Approved

1. Purpose

This Vulnerability and Patch Management Policy establishes CyroPay Ltd's requirements for identifying, assessing, and remediating technical vulnerabilities across all information systems and technology infrastructure. Effective vulnerability management is critical to protecting CyroPay's payment platform, customer data, and regulatory standing.

This policy directly addresses a Critical finding from CyroPay's ISO 27001:2022 gap assessment — the absence of a formal vulnerability scanning programme and the lack of a defined patch management SLA — both of which expose CyroPay to known and exploitable security risks.

2. Scope

This policy applies to all CyroPay information systems, applications, network infrastructure, cloud services, and endpoint devices. It covers all technology assets under CyroPay's management including AWS cloud infrastructure, on-premise server and network equipment, employee endpoints, and third-party software components. It applies to all employees and contractors with responsibility for system administration, development, or IT operations.

3. Definitions

Term	Definition
Vulnerability	A weakness in a system, application, or process that could be exploited by a threat actor
CVE	Common Vulnerabilities and Exposures — a public catalogue of known security vulnerabilities
CVSS	Common Vulnerability Scoring System — a standardised scoring system for rating vulnerability severity
Critical Vulnerability	CVSS score 9.0–10.0 — requires immediate remediation
High Vulnerability	CVSS score 7.0–8.9 — requires remediation within 72 hours
Medium Vulnerability	CVSS score 4.0–6.9 — requires remediation within 30 days

Low Vulnerability	CVSS score 0.1–3.9 — requires remediation within 90 days
Patch	A software update that fixes a security vulnerability or software defect
Zero-Day	A vulnerability that is publicly known but for which no patch is yet available

4. Roles and Responsibilities

4.1 CISO

- Own and maintain this policy
- Review monthly vulnerability reports and risk acceptance decisions
- Approve exceptions and compensating controls for vulnerabilities that cannot be patched within SLA

4.2 IT Manager

- Own and operate the vulnerability scanning programme
- Prioritise and coordinate patching activities across all systems
- Produce monthly vulnerability management reports for the CISO
- Maintain the vulnerability register

4.3 Head of Development

- Ensure application and dependency vulnerabilities identified in the CI/CD pipeline are remediated within SLA
- Integrate dependency scanning into the development pipeline

4.4 All System Administrators

- Apply patches and system updates within defined SLA timeframes
- Report any patching obstacles to the IT Manager immediately

5. Policy Requirements

5.1 Vulnerability Scanning

- Automated vulnerability scans must be conducted across all systems on the following schedule:
- External network and application scanning — weekly
- Internal network and infrastructure scanning — monthly
- Cloud infrastructure scanning (AWS) — continuous via integrated tooling
- Endpoint scanning — monthly
- Scanning must be performed using an approved vulnerability scanning tool
- Scan results must be reviewed within two business days of completion and loaded into the vulnerability register

5.2 Vulnerability Prioritisation

All identified vulnerabilities must be assessed using CVSS scoring and prioritised as follows:

- Critical (CVSS 9.0–10.0) — remediate within 24 hours
- High (CVSS 7.0–8.9) — remediate within 72 hours
- Medium (CVSS 4.0–6.9) — remediate within 30 days
- Low (CVSS 0.1–3.9) — remediate within 90 days
- Actively exploited vulnerabilities regardless of CVSS score must be treated as Critical

5.3 Patch Management

- All operating systems, applications, firmware, and third-party components must be kept up to date with security patches

- Security patches must be applied within the SLA timeframes defined in section 5.2
- Patches must be tested in the non-production environment before deployment to production wherever operationally feasible
- All patch deployments to production must follow the change management process
- End-of-life systems and software that can no longer receive security patches must be identified, risk assessed, and either replaced or subject to compensating controls approved by the CISO

5.4 Vulnerability Register

- All identified vulnerabilities must be logged in the vulnerability register maintained by the IT Manager
- The register must record: CVE reference, affected system, CVSS score, severity rating, discovery date, assigned owner, remediation date, and status
- The vulnerability register must be reviewed monthly by the CISO
- Overdue remediations must be escalated to the CISO within five business days of SLA breach

5.5 Zero-Day Vulnerabilities

- Zero-day vulnerabilities affecting CyroPay systems must be assessed and escalated to the CISO within four hours of discovery
- Compensating controls must be implemented immediately where patches are not yet available
- The CISO must determine whether the zero-day constitutes a reportable incident under FCA or UK GDPR requirements

5.6 Configuration Management

- All systems must be deployed and maintained in accordance with approved hardening baselines aligned to CIS Benchmarks
- Configuration drift from approved baselines must be detected through automated scanning and remediated within 30 days
- Hardening baselines must be reviewed and updated annually or when significant new threats emerge

5.7 Penetration Testing

- An independent penetration test must be conducted annually covering all external-facing applications, internal networks, and AWS infrastructure
- Penetration test findings must be remediated according to the severity SLAs defined in section 5.2
- Penetration test reports and remediation evidence must be retained for three years

6. Compliance and Monitoring

Compliance with this policy shall be monitored through:

- Internal audits and policy reviews
- Risk assessments and vulnerability assessments
- Security monitoring activities
- Management review meetings

Violations of this policy may result in disciplinary action, termination of access privileges, or legal escalation where appropriate.

7. Exceptions

Any exception to this policy must:

- Be formally documented with a business justification
- Be risk assessed and approved by the CISO
- Include compensating controls where necessary
- Be reviewed periodically and include an expiration date if temporary

8. Related Documents

- POL-001 Information Security Policy
- POL-003 Access Control Policy
- POL-005 Incident Response Policy
- POL-008 Secure Development Policy

9. ISO 27001 Annex A Mapping

Annex A Control	Description
A.8.8	Management of technical vulnerabilities
A.8.9	Configuration management
A.8.19	Installation of software on operational systems
A.8.29	Security testing in development and acceptance

10. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version